

ЛЕКЦИЯ 4

**Технологии за автентикация,
оторизация и отчетност. Протоколи.**

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

AAA (Authentication, Authorization, Accounting)

Автентикацията (удостоверяването) е процесът на доказване на самоличността си на някой друг.

Оторизацията (разрешение/упълномощаване) е процесът, при който се определя дали на удостовереното лице/процес да бъде разрешен достъп до защитените ресурси или системи. Процесът, чрез който достъпа до тези ресурси се ограничава за определен брой потребители, се нарича **контрол на достъпа**.

Отчетността (акаунтинг) – е процесът, при който се събира информация за използването на определени ресурси.

МРЕЖОВО АДМИНИСТРИРАНЕ

Пример:

Ако процес се свързва с файлов сървър и заявява „Аз съм процесът на *User111* и искам да изтрия файл *profile.dat*“, то отговорът на следните въпроси представлява:

1. Това наистина ли е процесът на *User111*?
(автентикация – удостоверяване)
2. Разрешено ли му е на *User111* да изтрива *profile.dat*?
(оторизация - разрешение)

МРЕЖОВО АДМИНИСТРИРАНЕ

Как се изпълнява процесът на автентикация?

Автентикационните данни (credentials: user ID и password) на потребителя се сравняват с тези съдържани в базата данни за потребителите в:

- Локална база данни на операционната система
- База данни на автентикационен сървър

МРЕЖОВО АДМИНИСТРИРАНЕ

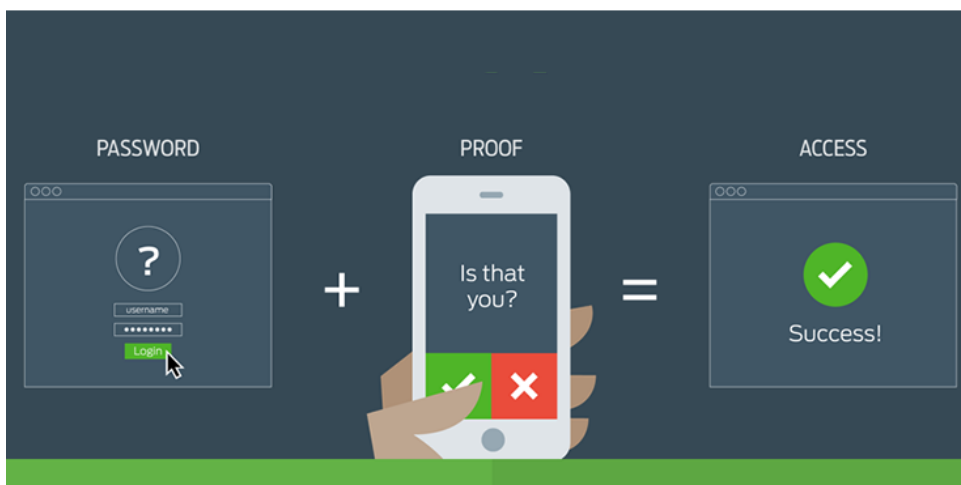
Фактори за автентикация

- Име и парола (single-factor authentication);
- Строга автентикация (strong authentication) – надежден и устойчив на атаки метод на автентикация, използващ обикновено повече от един фактор за автентикация:
 - **„Нещо, което знам“** - username, password, PIN, отговор на таен въпрос и др.
 - **„Нещо, което притежавам“** - токън, мобилен телефон за се приеме SMS или да се генерира One-Time-Password (OTP);

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Фактори за автентикация



доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Фактори за автентикация

- **„Нещо, което ми е присъщо“** - обикновено биометрични данни;
- **„Къде се намирам?“** - фактор, който обикновено се използва съвместно с други фактори, и е базиран на позиция в пространството (GPS) или в мрежата (IP или MAC address);
- **Време на автентикация** - фактор, който обикновено се използва съвместно с други фактори, и служи като допълнителен механизъм за удостоверяване;

МРЕЖОВО АДМИНИСТРИРАНЕ

2FA и MFA

- За да бъде двуфакторна автентикацията тя трябва да използва **два фактора от различен тип**. Името и паролата са фактори от един и същ тип (нещо, което знам) и не са достатъчни за да имаме 2FA. Същото се отнася и автентикация използваща отговор на таен въпрос;
- MFA обикновено използва три или повече фактори от различен тип, например: име и парола(1), биометрични данни (2), позиция (3) и време (4);

МРЕЖОВО АДМИНИСТРИРАНЕ

Методи на автентикация

1. Еднопосочна автентикация с парола - потребителя доказва идентичността си чрез демонстриране на знание за някаква тайна

Недостатъци:

- паролите се предават като чист текст (могат да бъдат прослушани)
- паролите са лесно за отгатване (потребителите използват лесни за запомняне пароли)
- автентикацията е еднопосочна (фалшиви сайтове, промптове / IP spoofing)

Методи на автентикация

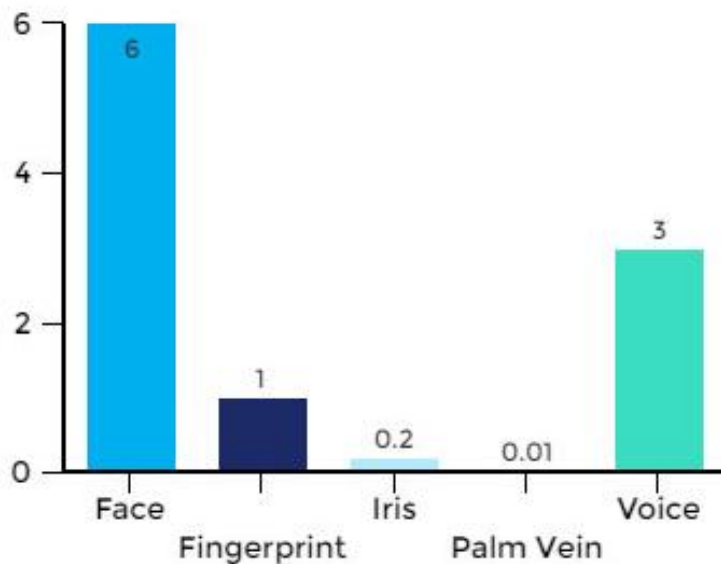
2. Биометрична автентикация – базирана на разпознаване на биометрични особености като глас, пръстови отпечатъци, вени, ръчен подпис и други

Недостатъци:

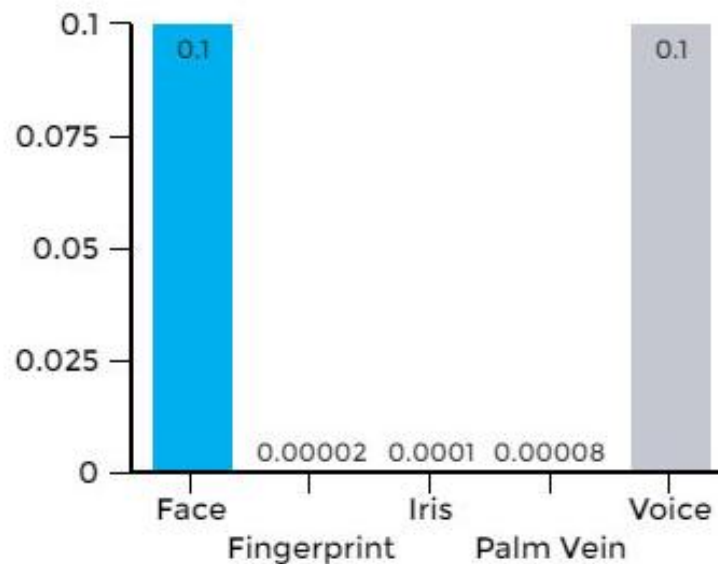
- проблеми свързани с грешно разпознаване
- скъпа поддръжка на хардуера и софтуера
- биометричната информация понякога се пренася като текст

МРЕЖОВО АДМИНИСТРИРАНЕ

Методи на автентикация



False Rejection Rate

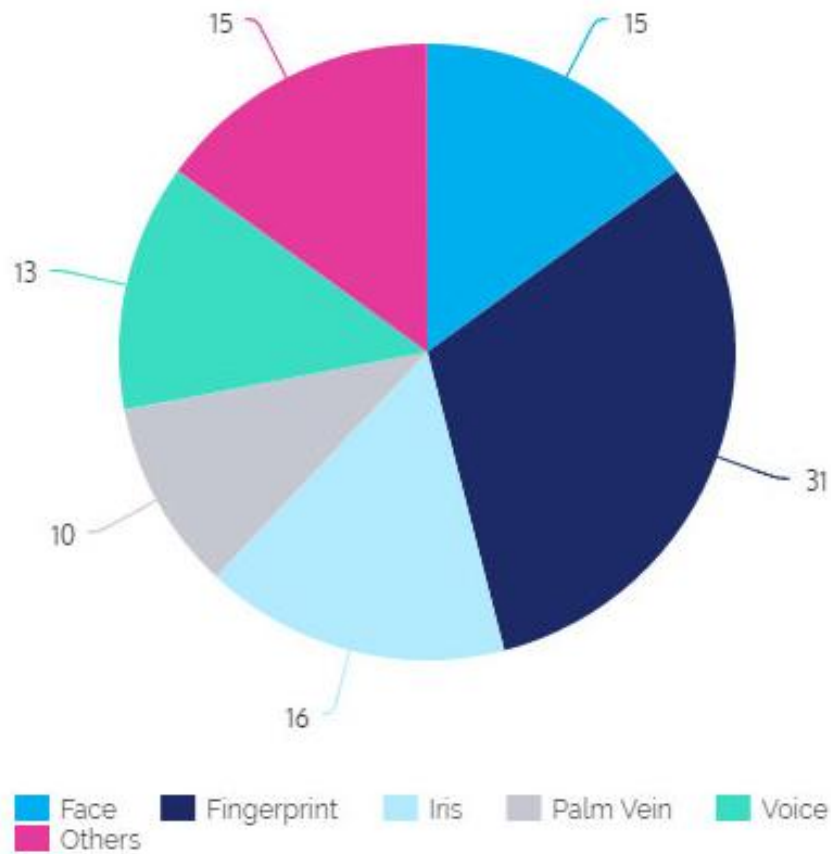


False Acceptance Rate

<https://www.biometric.com>

МРЕЖОВО АДМИНИСТРИРАНЕ

Методи на автентикация



<https://www.bayometric.com>

доц. д-р инж. Росен Радков

Методи на автентикация

3. Автентикация използваща криптографски методи

- съчетава техниката на удостоверяване с тази на разпространение на ключове;
- процесът на удостоверяване е свързан с демонстриране на способността да се криптира и декриптира даден елемент с ключ (частен или публичен);
- ключът обикновено не се променя често;

МРЕЖОВО АДМИНИСТРИРАНЕ

Методи на автентикация

- гарантирането, че елементът, който се криптира /декриптира/ е различен за всяко изпълнение на протокола може да стане чрез следните способности: timestamp, броячи или генератори на случайни числа.

Общият модел на автентикацията включва размяна на няколко съобщения между инициатора и ответника или доверен център за разпространение на ключове (Key Distribution Center – KDC), вследствие на което двете страни трябва да са сигурни с кого „говорят“ и да са създали ключ за криптиране на данните, които ще обменят.

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

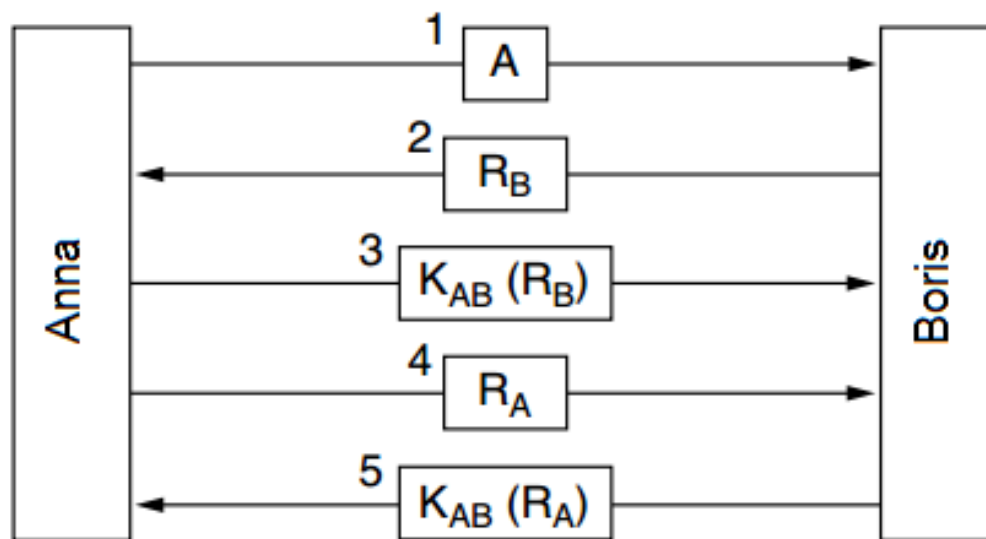
Методи на автентикация

За криптиране на данните се използва симетричен криптографски алгоритъм (AES или 3DES).

Може ли процесът на автентикация да бъде компрометиран?

МРЕЖОВО АДМИНИСТРИРАНЕ

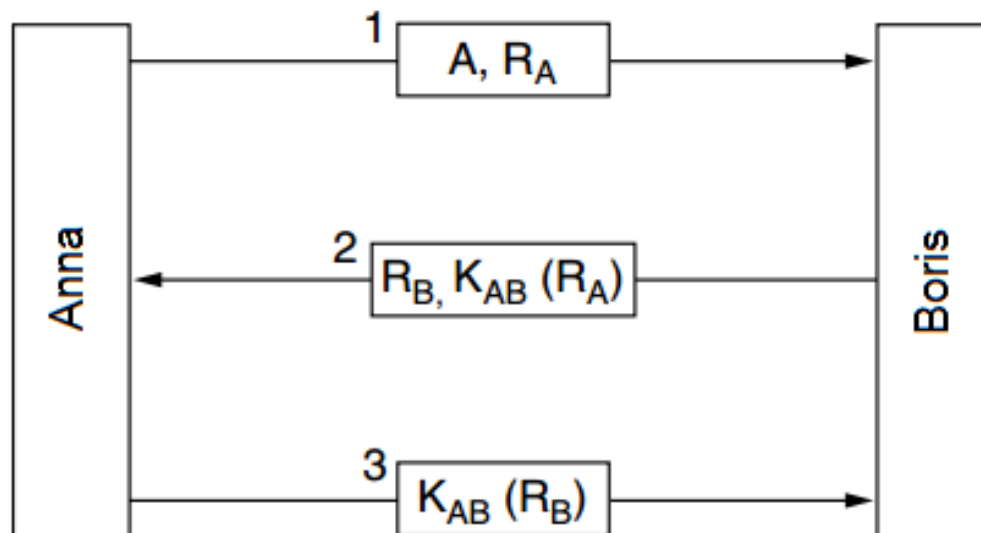
3.1. Автентикация със споделен ключ (shared secret key) с 5 съобщения – challenge-response протокол



A, B – данни представящи идентичността на Anna и Boris
R_i – поканата за предоставяне на паролата, i – показва кой изпраща поканата, в случая голямо случайно избрано число (128бита)
K_{AB} – споделен ключ, известен само на Anna и Boris

МРЕЖОВО АДМИНИСТРИРАНЕ

3.2. „Скъсена“ автентикация базирана на споделен ключ (shared secret key) – с 3 съобщения



A, B – данни представящи идентичността на Anna и Boris

R_i – поканата за предоставяне на паролата, i – показва кой изпраща поканата, в случая голямо случайно избрано число

K_{AB} – споделен ключ, известен само на Anna и Boris

МРЕЖОВО АДМИНИСТРИРАНЕ

По-добра ли е автентикацията, изпълнявана с три стъпки, спрямо тази с пет стъпки?

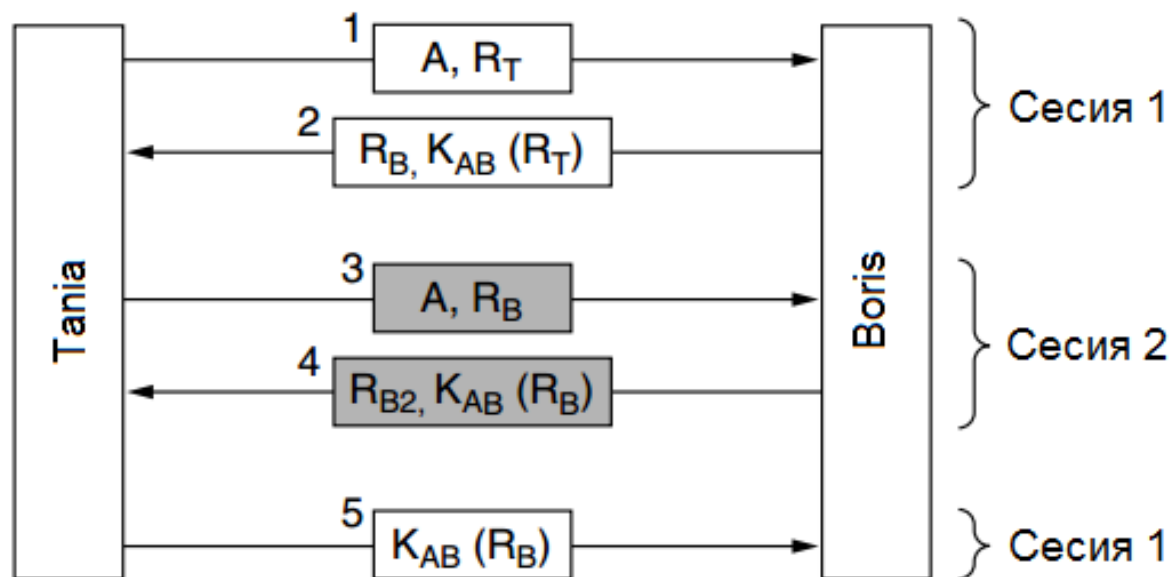
1. Да, по-къса е, т.е. изпълнява се по-бързо!

2. Ноооооо, дали е по-сигурна?

- За съжаление НЕ! Податлива е на т.н. reflection attack

МРЕЖОВО АДМИНИСТРИРАНЕ

Reflection attack при протокол с 3 стъпки



Описаната ситуация е реална, тъй като има случаи, при които са възможни множество сесии изградени от един и същ източник

МРЕЖОВО АДМИНИСТРИРАНЕ

Извод: Разработката на надежден протокол за автентикация е по-трудно отколкото изглежда!

Основни правила, които трябва да бъдат спазвани при разработка на протоколи за автентикация:

1. Инициаторът трябва да докаже кой е преди ответникът да отговори.
2. Инициаторът и ответникът трябва да използват различни ключове (K_{AB} и K_{AB}') за доказване на идентичността.

МРЕЖОВО АДМИНИСТРИРАНЕ

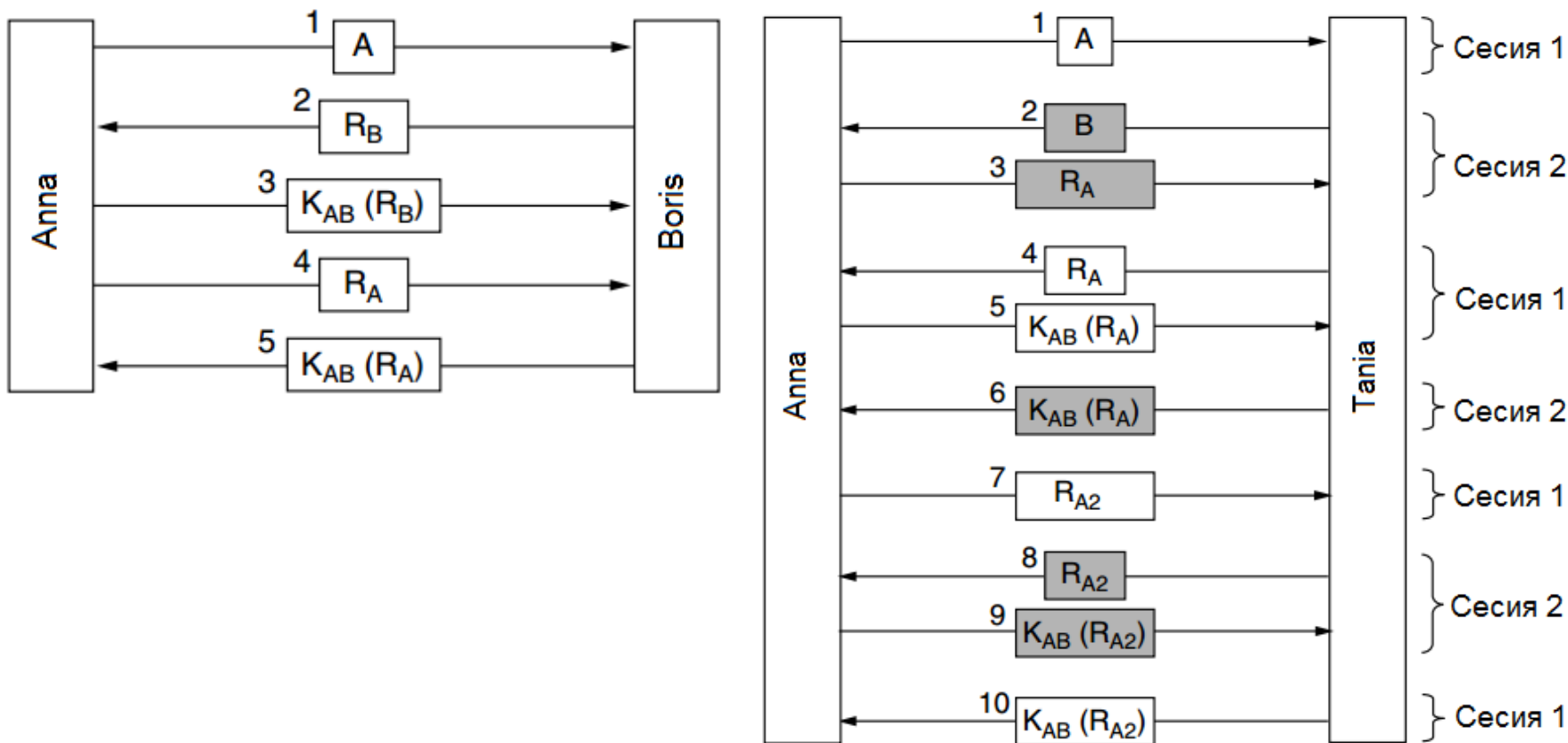
3. Инициаторът и ответникът трябва да избират числата използвани за покана от различни множества, например първият да използва четни, а вторият нечетни числа.

4. Протоколът да бъде устойчив на атаки, които създават втора сесия, в която използват информацията получена в първата сесия.

Нарушаването дори на само на едно от четирите правила води до компрометиране на автентикацията!

МРЕЖОВО АДМИНИСТРИРАНЕ

Reflection attack при протокол с 5 стъпки

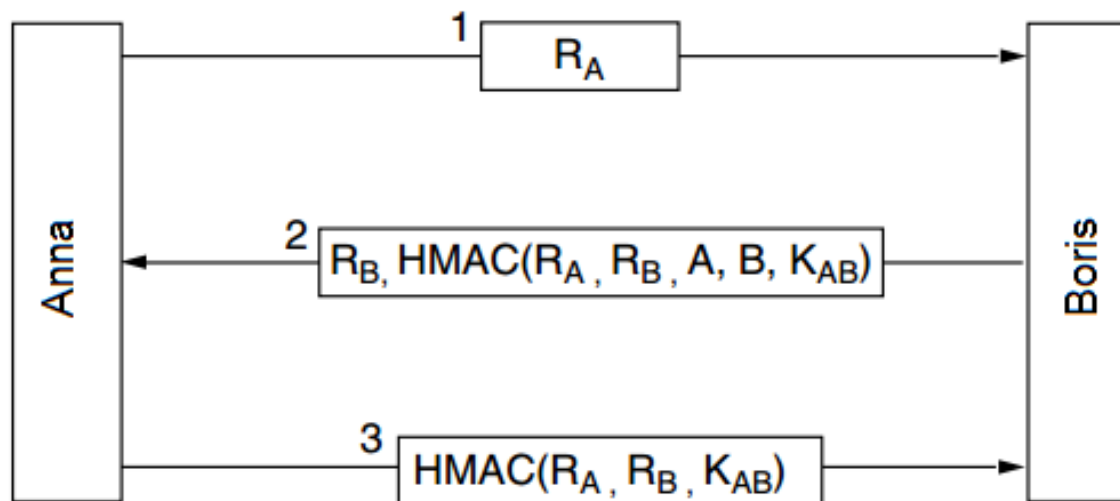


В резултат имаме две удостоверени сесии!

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

3.3. Автентикация използваща НМАС за предотвратяване на атаки



A, B – данни представящи идентичността на Anna и Boris

R_i – покана за предоставяне на паролата, i – показва кой изпраща поканата, в случая голямо случайно избрано число

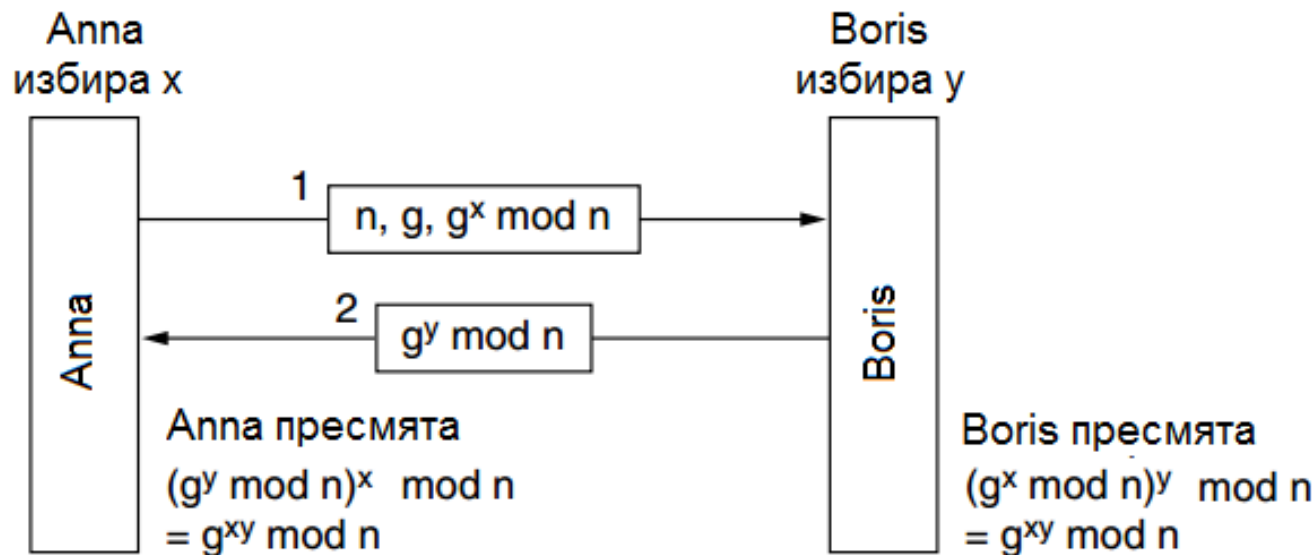
K_{AB} – ключ, известен само на Anna и Boris

Като НМАС може да се използва например SHA-1

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

3.4. Установяване на споделен ключ: Diffie-Hellman алгоритъм



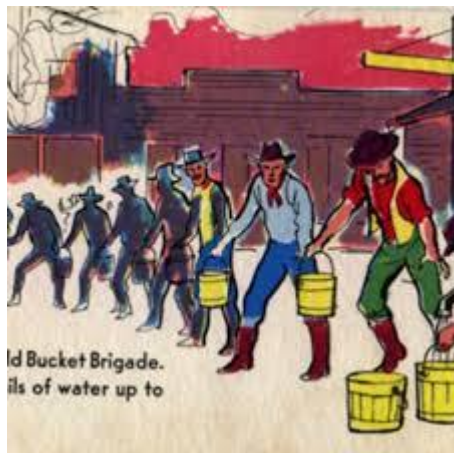
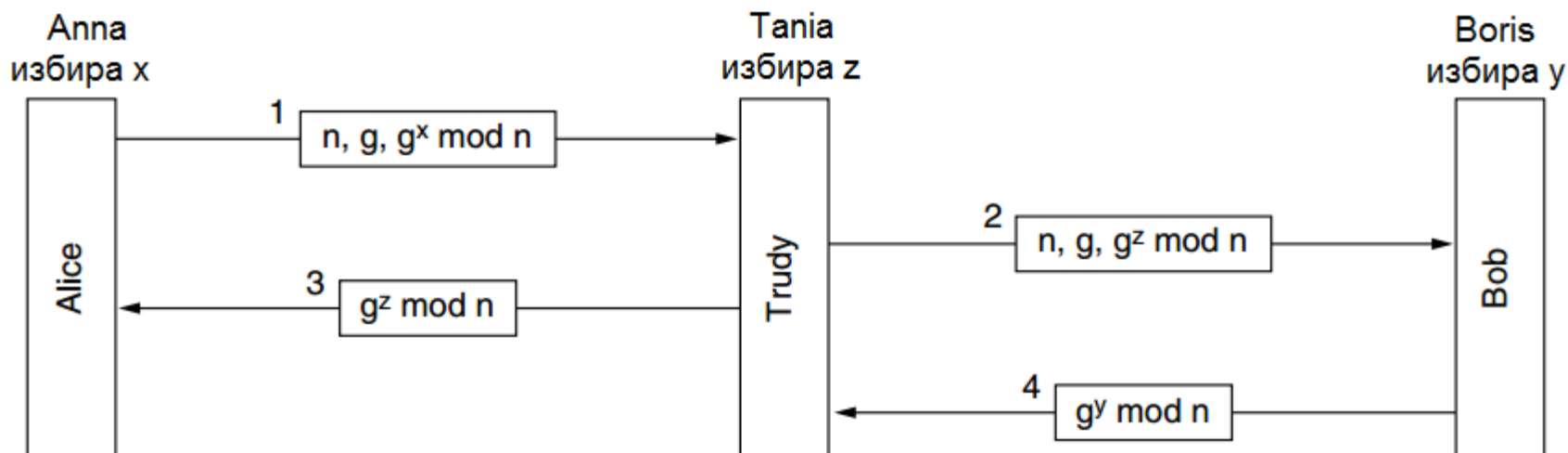
- n, g, x и y – големи (1024 бита) числа (n и g са прости числа)
- Споделеният ключ е $g^{xy} \bmod n$

Няма бърз алгоритъм, чрез който да бъдат пресметнати x и y , тъй като са големи числа.

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Потенциален проблем: Man-In-The-Middle (MITM)

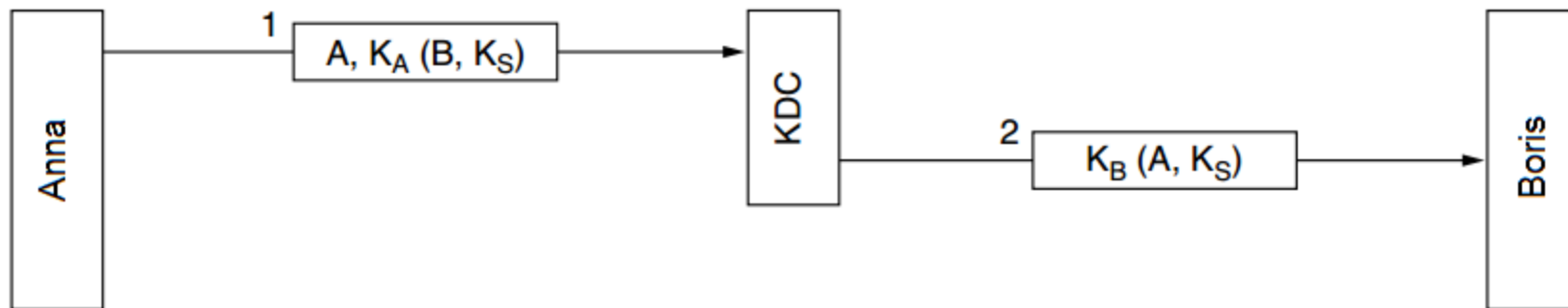


Тази атака е известна още с името:
„bucket brigade attack“

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

3.5. Автентикация чрез доверен център за разпространение на ключове (Key Distribution Center – KDC).



K_A – секретен ключ известен на KDC и A; K_S – сесиен ключ, генериран от Anna

KDC решава проблем свързан с това, че за комуникация с много хора всеки един ще трябва да се поддържа голям брой ключове. В този модел всеки потребител има само един ключ, споделен с KDC. Управлението на автентичността и управление на сесиите преминават през KDC.

Потенциален проблем – т.н. replay attack!

доц. д-р инж. Росен Радков

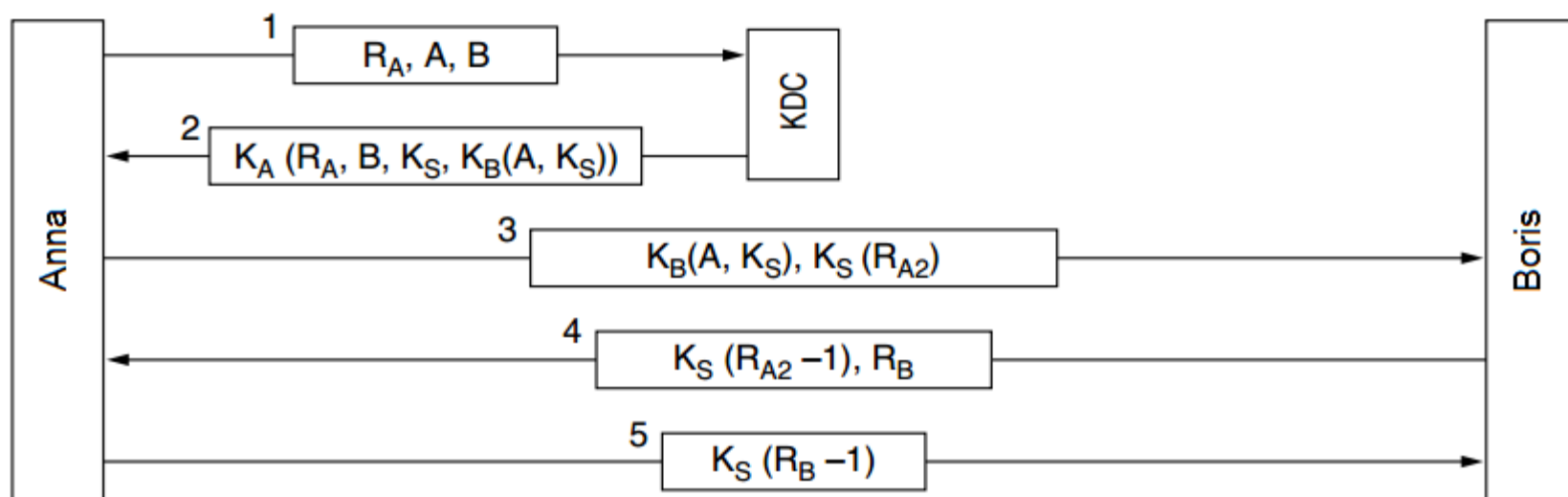
3.5. Автентикация чрез доверен център за разпространение на ключове (Key Distribution Center – KDC).

Пример за replay attack!

След извършена за Анна работа, Тania иска от Анна тя да и бъде заплатена. Анна установява сесиен ключ с банкера си Boris, след което му изпраща криптирано съобщение, в което иска да бъдат прехвърлени пари в сметката на Tania. Tania копира съобщение 2 и искането за паричен превод и ги изпраща повторно /а може и много пъти :-)/ към банкера.

МРЕЖОВО АДМИНИСТРИРАНЕ

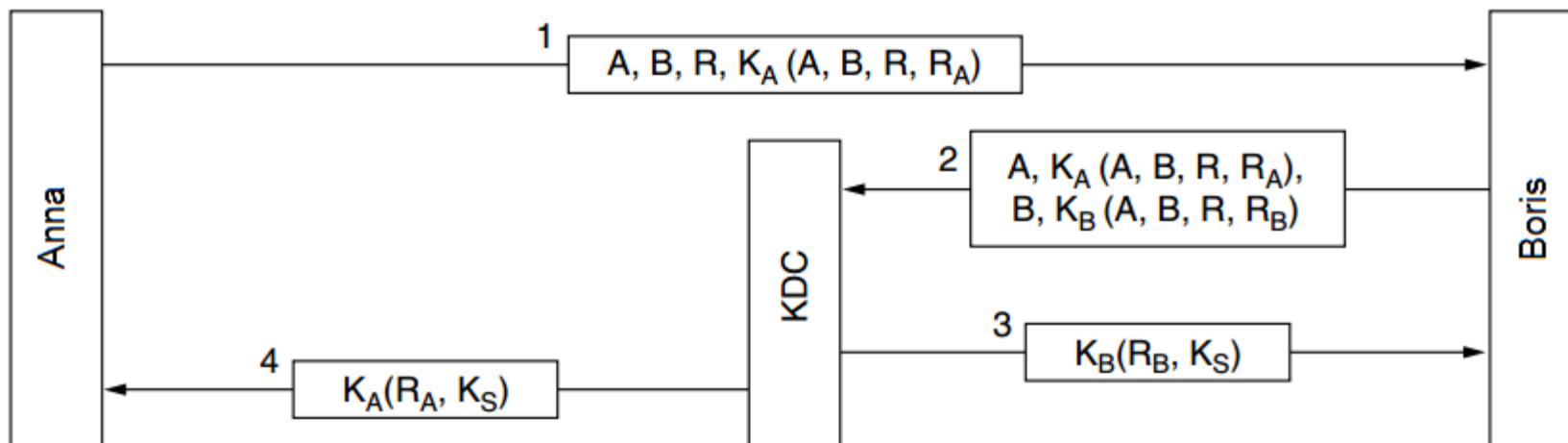
3.6. Автентикация чрез KDC и протокол Needham-Schroeder (1978).



$K_B(A, K_S)$ - тикет

МРЕЖОВО АДМИНИСТРИРАНЕ

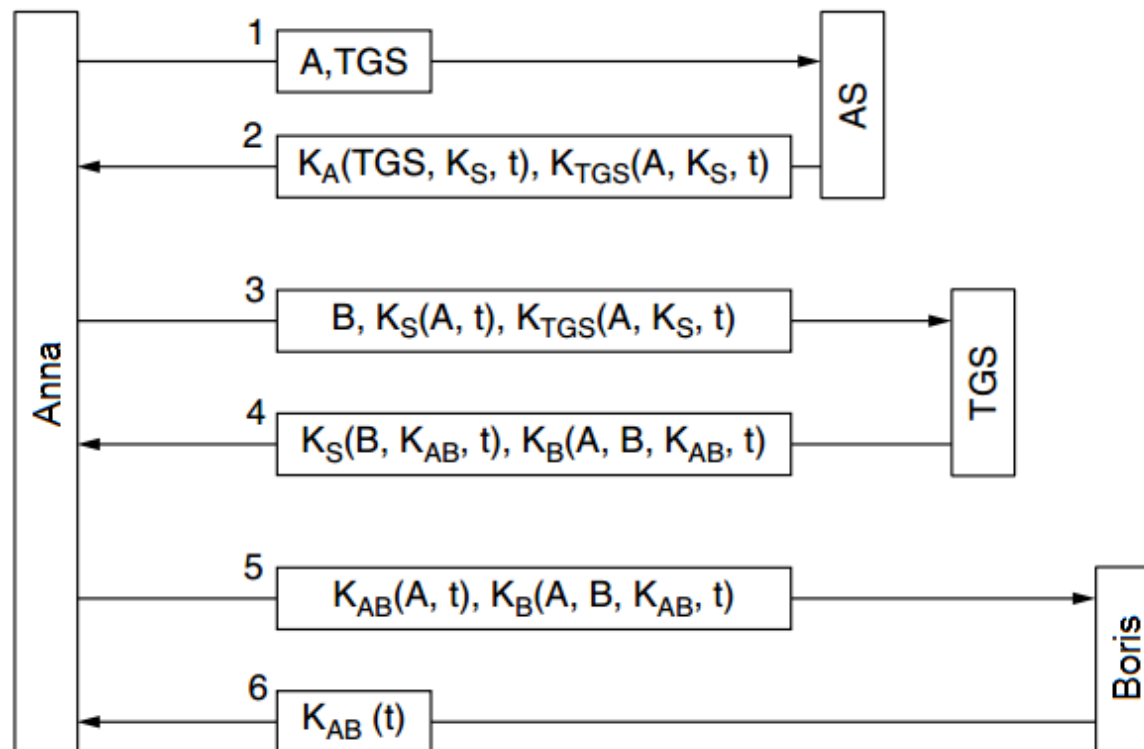
3.7. Автентикация чрез KDC и протокол Otway-Rees (1987).



МРЕЖОВО АДМИНИСТРИРАНЕ

3.8. Автентикация чрез KDC и протокол Kerberos (V5 е дефинирана в RFC 4120)

AS – authentication server, изпълняващ роля на KDC, който прави проверка на потребителя в момента на „login“ чрез споделяне на секретна парола с всеки един потребител

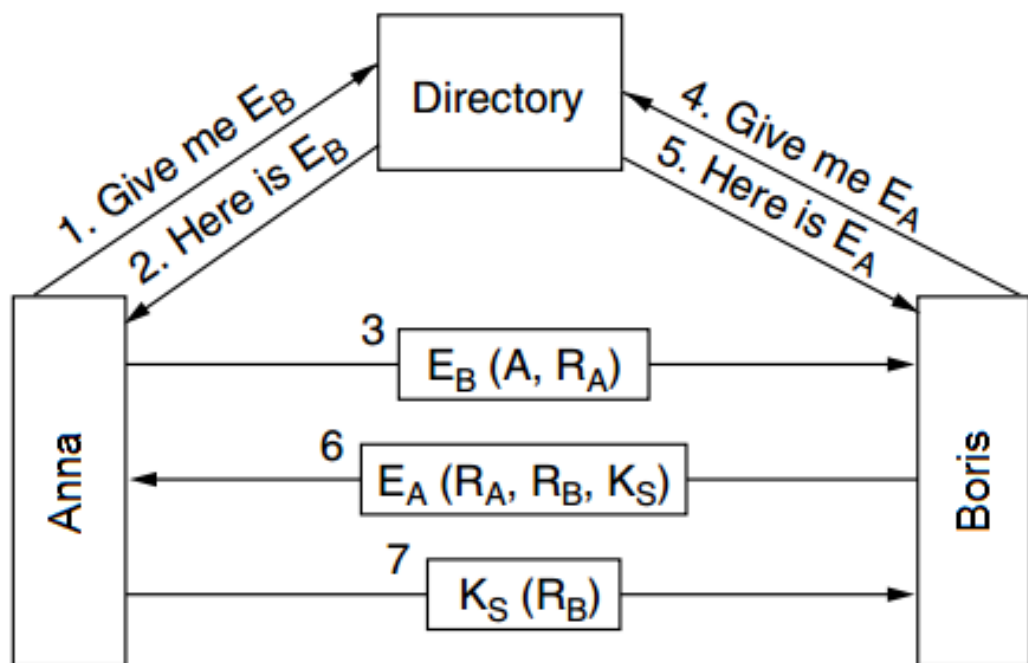


TGS – Ticket-Granting Server – издава тикети, които удостоверяват приносителя им

Boris – сървър, до който се иска достъп

МРЕЖОВО АДМИНИСТРИРАНЕ

3.9. Автентикация чрез PKI, използваща публичен и частен ключ.



1. Anna иска публ.ключ на Boris
2. Anna получава X.509 сертификат, съдържащ публичния ключ на Boris
3. Ако сертификатът е ОК, Anna се идентифицира пред Boris, като изпраща и R_A
4. Boris иска публ.ключ на Anna

5. Boris получава публ. ключ на Anna.

6. Boris изпраща на Anna идентификация и сесийен ключ

7. Anna изпраща на Boris R_B криптирано със сесийния ключ

4. Оторизация

В основата си, оторизацията означава да се определи какво е позволено на клиента да прави в мрежата. Вариантите на оторизация по отношение на достъп до мрежата са:

- Без оторизация
- Сегментиране на Layer 2 – използване на VLAN, ACL
- Филтриране на Layer 3 – чрез ACL се налагат разрешения до група хостове, конкретен хост или услуги работещи върху хоста;
- Разрешения определяни на Layer 7 – от приложенията;
- Размяна на информация за идентичности вследствие, на което се подава информация към автентикаторите за прилагане на действията;

5. Отчетност

- Все по-критична стъпка в цялостния AAA процес;
- Отчита се времето на осъществяване на достъпа и кога е прекъснат;
- Отчита се времето на извършване на определени операции;
- Използва се за:
 - заплащане на услугите;
 - съставяне на статистика за използването на услугите;
 - разпределяне на разходи между отделите/фирми;

МРЕЖОВО АДМИНИСТРИРАНЕ

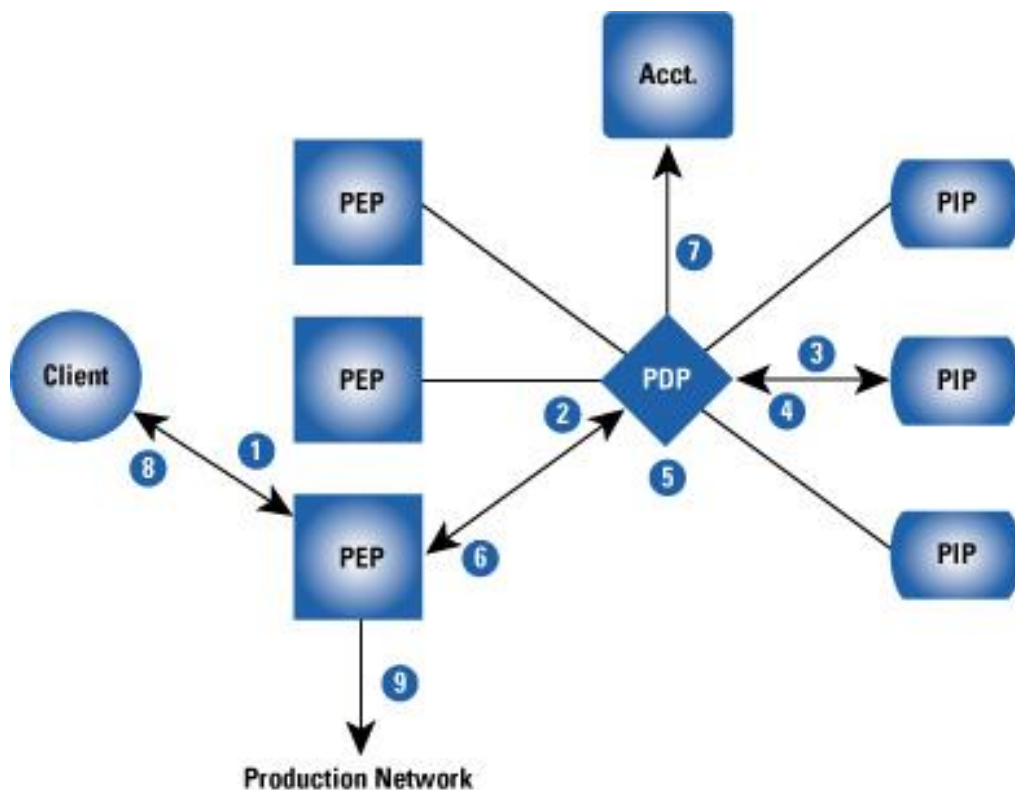
- анализ на събитията на база корелация на събитията;
- планиране на капацитета;

6. Основни компоненти на AAA

- Клиент – потребител/устройство, което се опитва да достъпи ресурс;
- Автентикатор (Policy Enforcement Point – PEP) – прилагане на условията за достъп;
- Хранилище на информация (Policy Information Point – PIP) – съхранява информация необходима за вземане на решение за предоставяне на достъп;
- AAA сървър (Policy Decision Point – PDP) – взема решение за предоставяне на достъп;
- Система за отчетност и справки (Accounting and Reporting System) – дава възможност да се проследи използването на ресурсите.

МРЕЖОВО АДМИНИСТРИРАНЕ

6. Основни компоненти на AAA



1. Клиент се опитва да установи достъп до мрежата и изпраща поисканата информация на PEP

2. PEP изпраща събраната информация на PDP

3. PDP изпраща запитвания към PIP

4. PIP връщат потвърждение/отказ след валидиране на получената информация

5. PDP оценява събраната информация и взема решение

6. PDP изпраща на PEP резултата от процесите на автентикация и оторизация

7. PDP изпраща данни към системата за отчетност

8. PEP прилага оторизацията

9. Клиентът получава достъп до мрежата чрез PEP.

доц. д-р инж. Росен Радков

7. Протоколи

7.1 За автентикация: PAP, CHAP и MS-CHAP

7.2 RADIUS

7.3 DIAMETER

7.4 TACACS/TACACS+

МРЕЖОВО АДМИНИСТРИРАНЕ

➤ Password Authentication Protocol (PAP)



- RFC 1334, Октомври 1992
- автентикаторът изпраща покана (challenge) за автентикация
- клиента отговаря с име и парола (текст)
- автентикаторът изпраща отговор success/failure

МРЕЖОВО АДМИНИСТРИРАНЕ

➤ Challenge Handshake Authentication Protocol (CHAP)



- RFC 1994, Август 1996г
- автентикаторът изпраща покана (challenge) за автентикация
- клиента отговаря с MD5 хеш стойност на данните
- автентикаторът също изчислява MD5 хеш стойността на данните и изпраща отговор success/failure
- изисква двете страни да знаят паролата в текстови вид

МРЕЖОВО АДМИНИСТРИРАНЕ

➤ Microsoft CHAP и MS-CHAP v2

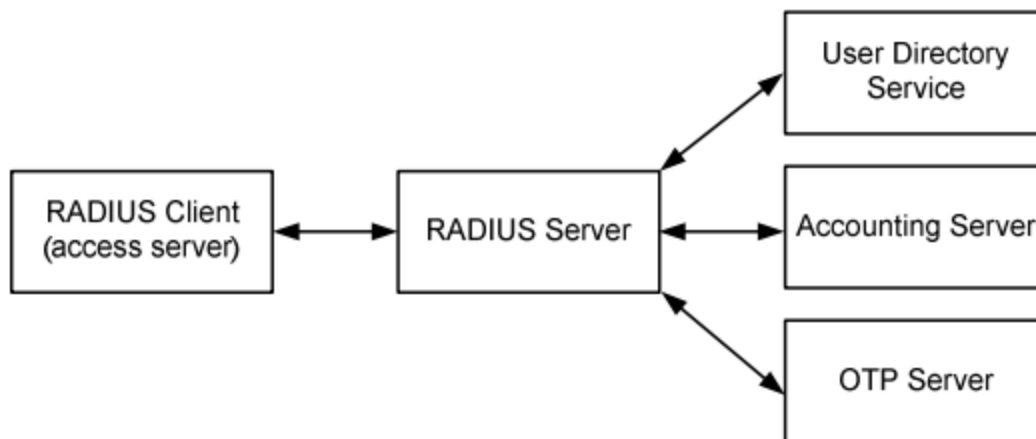


- RFC 2433, Октомври 1998г
- не изисква парола в текстови вид
- използва хеш стойност на паролата
- автентикаторът изпраща заявка за автентикация
- позволява клиента да сменя паролата
- при v2 (RFC 2759, Януари 2000) се прави двустранна автентикация
- при v2 не може да се сменя паролата

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

➤ Remote Authentication Dial-In User Service (RADIUS)

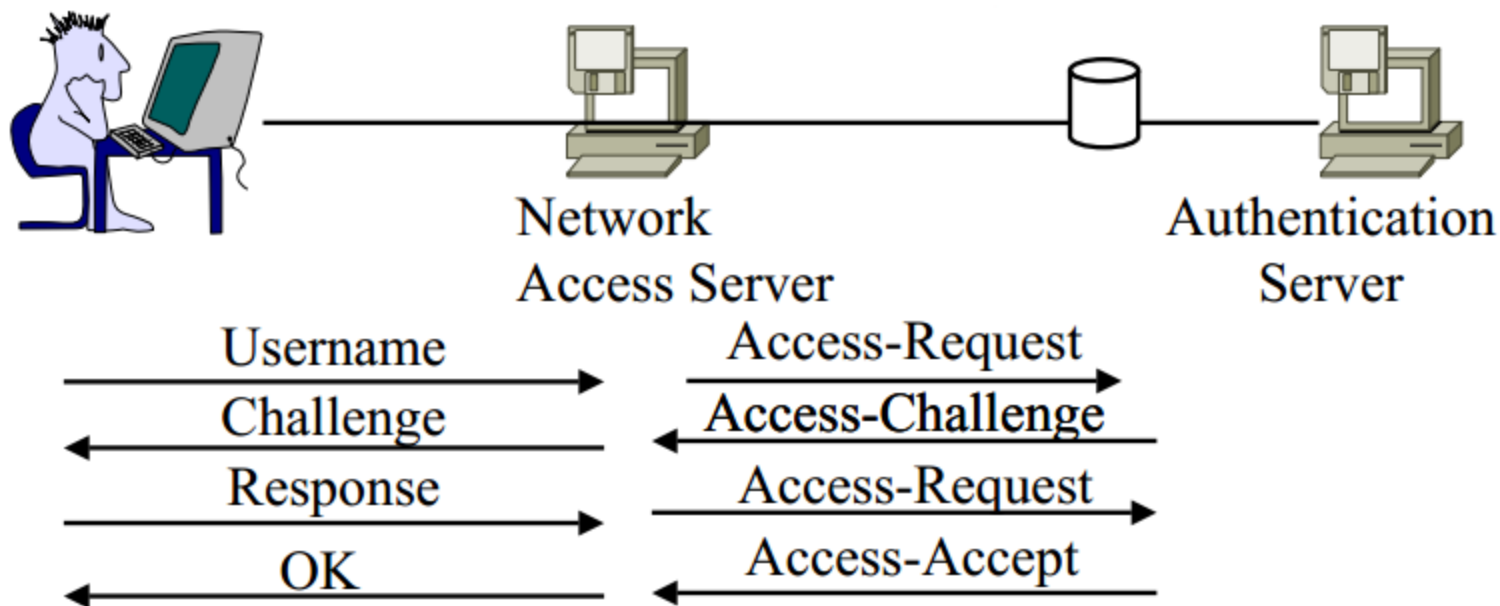


- обикновено действа като междинна услуга, която реализира AAA;
- криптира паролата;
- не криптира всички атрибути;
- осигурява ролята „отчетност“;
- може да работи с допълнителни услуги като OTP;
- дава възможност за RADIUS проху сървъри;

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

➤ Remote Authentication Dial-In User Service (RADIUS)



- четири съобщения: Request, Challenge, Accept, Reject

Code	Identifier	Length	Authenticator	Attributes
1B	1B	2B	16B	

➤ Remote Authentication Dial-In User Service (RADIUS)

- Кодове:
 - 1=Access Request
 - 2=Access Accept
 - 3=Access Reject
 - 4=Accounting request
 - 5=Accounting response
 - 11=Access Challenge
 - 12=Server Status (experimental)
 - 13=Client Status (experimental)
 - 255=Reserved

➤ Проблеми при RADIUS

- Stateless и използва UDP
- Не поддържа failover механизъм
- Не поддържа сигурност от край-до-край
- IPSec е като опция
- Ограничен брой на връзките
- Възможни са **replay** атаки
- Няма съобщения за грешка

МРЕЖОВО АДМИНИСТРИРАНЕ

➤ Diameter Base Protocol (RFC 3588 и RFC 6733)

- разширен RADIUS
- използва UDP, TCP, SCTP
- може да бъде в една мрежа с RADIUS
- поддържа стандартен механизъм за фейловър
- всички данни се предават във вид на Attribute-Value-Pairs (AVP)
- поддържа специфични за конкретен производител AVP и команди
- peer-to-peer протокол, т.е. всеки възел може да инициира заявка
- поддържа:
 - Съобщения за грешки
 - Намиране на имена на сървъри чрез DNS
 - Договаряне на параметрите на връзката
 - Добавяне на нови команди към AVP

МРЕЖОВО АДМИНИСТРИРАНЕ

БЛАГОДАРЯ ЗА ВНИМАНИЕТО!

доц. д-р инж. Росен Радков